AI Agent Governance Control Framework Harbor Federal Bank

This framework makes every AI agent at Harbor Federal known, owned, bounded, supervised, auditable and stoppable, through 26 controls scaled by risk tier. Harbor Federal is a fictional mid-size US bank used for this portfolio.

Why I wrote this

This year I've worked on agent identity standards: maintaining TRAIL, a W3C-registered identifier method for AI agents, and co-authoring W3C text on what an audit record can prove about an agent's actions. The same gap kept coming up. Every framework says to govern AI agents, but none says how to prove which agent did something, on whose authority, and whether the record shows what actually ran.

In April 2026, US bank regulators replaced SR 11-7 with SR 26-2 and explicitly left generative and agentic AI out of its scope, so banks now have to build that governance themselves. This framework is my answer for a bank. I wrote it so a model risk team could adopt it and an examiner could test it.

Scope and tiering

An **AI agent** is an AI system that plans and takes actions through tools or APIs, such as sending messages, updating records, moving money or calling other systems, with some degree of autonomy. This framework covers every agent Harbor Federal builds, buys, or uses inside vendor software. A chatbot that only answers questions falls under the AI & Model Risk Policy; it becomes an agent here the moment it can act.

Autonomy levels set what an agent may do without a human.

Level	Name	What the agent can do	Example
L0	Suggest	Drafts or recommends; a human performs every action	Drafts a collections email for an officer to send
L1	Act with approval	Acts only after a human approves each action	Sends the email after an officer approves it

Level	Name	What the agent can do	Example
L2	Act within bounds	Acts alone within set limits; humans review a sample	Sends routine payment reminders; 10% reviewed weekly
L3	Autonomous	Acts alone; humans review exceptions only	Not permitted for customer-facing or financial actions

Tiering scores each agent 1 to 3 on five factors. The total sets the tier, and overrides beat the total.

Factor	1 (low)	2 (medium)	3 (high)
Action reach	Read-only, internal	Writes to internal systems	External, financial or irreversible actions
Autonomy	L0	L1	L2 or L3
Data sensitivity	Public or internal	Confidential	Customer financial or personal data
Scale	One team	One business line	Customers or bank-wide
Regulatory exposure	None identified	Indirect	Direct: consumer protection, fair lending, privacy

A total of 5 to 8 is Tier 3, 9 to 11 is Tier 2, and 12 to 15 is Tier 1.

Overrides: an agent that can take an external, financial or irreversible action affecting a customer, or that feeds a regulatory report, is Tier 1 whatever its score. Any change to an agent's tools, permissions, data sources, model or autonomy level triggers re-tiering (control A3).

Principles

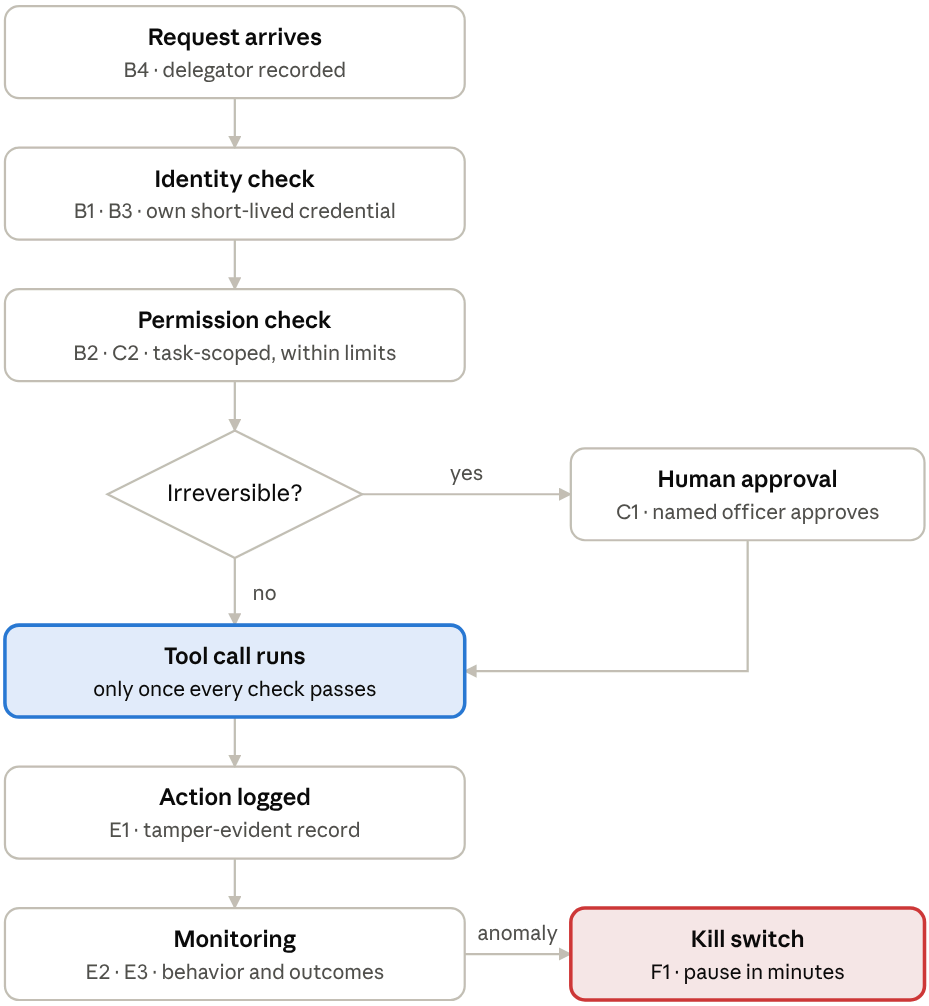
Every control in this framework traces back to one of five rules.

1. **Every agent is an identity.** An agent acts under its own identity, never a shared service account or a person's login. If you can't name which agent did something, you can't govern it.

2. **Least agency, not just least privilege.** Limit what an agent *can* do (its tools), what it *may* touch (its permissions), and how far it acts *alone* (its autonomy level). Excess in any one is a risk on its own.
3. **Humans own outcomes.** Every agent has a named person accountable for what it does, and every action traces back to the human or system that authorized it.
4. **Provable, not plausible.** Controls produce evidence an auditor can test. A log that records what the agent claimed it did, but not what actually ran, is not evidence.
5. **Stoppable by design.** Any agent can be paused in minutes, by more than one person, without a code release.

Control path

Every action clears three checks before it runs and leaves a record



agent action path · 7 steps, 1 decision, 2 branches

Read it top to bottom. An action runs only after the identity and permission checks pass, plus a named officer's approval if it can't be undone. Every run is logged and monitored, and an anomaly trips the kill switch, which hands off to the incident runbook (F2 to F4).

Controls

26 controls in six domains. Each one names its type, the tiers it applies to, the evidence an auditor would pull, and where it maps.

Mappings: **NIST** = NIST AI RMF 1.0 subcategory; **ISO** = ISO/IEC 42001 Annex A control area; **EU** = EU AI Act article, used as a design reference where the Act doesn't legally apply; **SR 26-2** = the 2026 interagency model risk guidance, which puts agentic AI outside its formal scope, so its principles are applied here by analogy; **OWASP** = OWASP Top 10 for LLM Applications.

A. Inventory and ownership: every agent is known and owned

ID	Control	Type	Tiers	Evidence	Maps to
A1	**Register before credentials.** Every agent is in the AI inventory, with purpose, owner, tools, data sources, model, autonomy level and tier, before IAM issues it any credential.	Preventive	All	Inventory record; IAM report showing every agent identity maps to an inventory ID	NIST GOVERN 1.6 · ISO A.4 · SR 26-2 inventory
A2	**Named accountable owner.** Each agent has a named business owner and a named technical custodian. The owner re-attests purpose, tools and permissions quarterly for Tier 1, semiannually otherwise.	Preventive	All	Owner field; signed attestations	NIST GOVERN 2.1 · ISO A.3
A3	**Tier and re-tier.** Agents are tiered at registration using the scoring in Scope. Any change to tools, permissions, data, model or autonomy triggers re-tiering before release.	Preventive	All	Tiering worksheet with rationale; change tickets linked to re-tier	NIST MAP 1.1 · ISO A.5 · SR 26-2 risk-based tailoring

ID	Control	Type	Tiers	Evidence	Maps to
A4	**Third-party agents covered.** Vendor agents and agentic features in SaaS go through the same registration. Procurement intake flags agentic capability; contracts require documentation, change notice, log access and incident notice.	Preventive	All	Procurement intake record; contract clauses	NIST GOVERN 6.1, MAP 4.1 · ISO A.10 · SR 26-2 third-party

B. Identity and access: every agent is bounded

ID	Control	Type	Tiers	Evidence	Maps to
B1	**Unique non-human identity.** Each agent runs under its own identity in IAM. No shared service accounts, and never an employee's credentials.	Preventive	All	IAM listing reconciled 1:1 to the inventory	NIST MEASURE 2.7 · ISO A.6 · EU Art. 15
B2	**Least agency.** Tools come from an allowlist. Permissions are scoped to the task, such as one customer record per task. Read, write and send are separate permissions; no wildcard scopes.	Preventive	All	Tool allowlist; permission manifest reviewed at validation	OWASP Excessive Agency · NIST MEASURE 2.7
B3	**Short-lived credentials.** Credentials are issued per task or session and expire in minutes. No long-lived secrets in prompts, code or configuration.	Preventive	T1–T2	Token issuance logs; secrets scan results	NIST MEASURE 2.7 · EU Art. 15

ID	Control	Type	Tiers	Evidence	Maps to
B4	**Recorded delegation.** Every action carries the identity of the human or system the agent acts for, for example through OAuth 2.0 token exchange (RFC 8693) with an actor claim. The agent can never exceed its delegator's own permissions.	Preventive	T1–T2	Sampled action logs showing the delegator; authorization test results	NIST MEASURE 2.8 · EU Art. 12
B5	**Access recertification.** The owner and Security review each agent's permissions quarterly for Tier 1, semiannually otherwise. Unused permissions are removed.	Detective	All	Recertification records; permission diffs	NIST MEASURE 2.7 · ISO A.6

C. Human oversight: every agent is supervised

ID	Control	Type	Tiers	Evidence	Maps to
C1	**Approval for irreversible actions.** External, financial or irreversible actions (messaging a customer, moving money, changing or closing an account) need a recorded human approval. The approver's identity is logged with the action.	Preventive	T1	Approval records joined to action logs	NIST MAP 3.5 · ISO A.9 · EU Art. 14
C2	**Action limits.** Caps on volume and value per hour and per day. Breaching a cap pauses the agent and alerts the owner.	Preventive	All	Configured limits; breach alerts	OWASP Excessive Agency · NIST MANAGE 2.4

ID	Control	Type	Tiers	Evidence	Maps to
C3	**Sampled review.** For L2 actions, a reviewer checks a set sample weekly, 10% for Tier 1. Errors are logged as issues.	Detective	T1–T2	Review logs; issue tickets	NIST MEASURE 2.4 · EU Art. 14
C4	**Mandatory hand-off.** The agent hands off to a human when a request is out of scope, a policy rule fires, confidence is low, or a customer disputes, complains or shows distress.	Preventive	Customer-facing	Hand-off rules; hand-off rate in monitoring	NIST MAP 3.5 · ISO A.9
C5	**Disclosure to affected people.** Customers are told when they are dealing with an AI agent or receiving AI-drafted messages, where law or policy requires it.	Preventive	Customer-facing	Disclosure text; message samples	EU Art. 50 · ISO A.8 · NIST MEASURE 2.8

D. Testing and change: every agent is proven before use

ID	Control	Type	Tiers	Evidence	Maps to
D1	**Pre-deployment validation.** Independent testing scaled to tier: task accuracy, policy compliance, fairness where customers are affected, and failure handling.	Preventive	All, depth by tier	Validation report with severity-rated findings	SR 26-2 validation · ISO A.6 · EU Art. 15

ID	Control	Type	Tiers	Evidence	Maps to
D2	**Adversarial testing.** The test suite covers prompt injection through retrieved content (emails, documents, web pages), cross-customer data access, privilege escalation and tool misuse. Each test is labeled fail-open or fail-closed, and any fail-open result blocks go-live. Re-run on every material change.	Preventive	T1–T2	Test suite, results and retest evidence	NIST MEASURE 2.7 · OWASP Prompt Injection
D3	**Change control.** Changes to model version, instructions, tools, permissions or data sources are logged. Material changes are re-validated before release. Vendor model versions are pinned, so a silent upgrade is caught.	Preventive	All	Change log; pinned version config; re-validation records	ISO A.6 · SR 26-2 change management

E. Logging and monitoring: every agent is auditable

ID	Control	Type	Tiers	Evidence	Maps to
E1	**Complete action log.** Every tool call is recorded as the receiving system executed it, not only as the agent declared it: agent ID, delegator, inputs, outputs, approval if any, and timestamp. Logs are tamper-evident and kept per the records schedule.	Detective	All	Log samples; integrity check results	EU Art. 12 · ISO A.6 · NIST MEASURE 2.8

ID	Control	Type	Tiers	Evidence	Maps to
E2	**Behavior monitoring.** Alerts on anomalous tool use: new tools, volume spikes, cross-customer access, off-hours activity. Thresholds are set at validation.	Detective	T1–T2	Alert rules; alert history	NIST MEASURE 2.4, MANAGE 4.1
E3	**Outcome monitoring.** Error rate, complaints, overrides, hand-off rate and, where relevant, outcomes by customer group. Reviewed monthly for Tier 1, quarterly otherwise.	Detective	All	Monitoring reports; committee minutes	NIST MANAGE 4.1 · EU Art. 72 · SR 26-2 ongoing monitoring
E4	**Periodic revalidation.** Tier 1 annually, Tier 2 every two years, Tier 3 by owner self-assessment.	Detective	All	Revalidation schedule and reports	SR 26-2 · NIST GOVERN 1.5

F. Incidents and retirement: every agent is stoppable

ID	Control	Type	Tiers	Evidence	Maps to
F1	**Kill switch.** The owner, Model Risk or Security can pause any agent within minutes without a code release, with credential revocation as the backstop. Tested quarterly for Tier 1.	Corrective	All	Kill-switch test records with time to pause	NIST MANAGE 2.4
F2	**Agent incident runbook.** Severity levels, who is paged, containment steps, evidence preservation and owner notification.	Corrective	All	Runbook; incident tickets	NIST MANAGE 4.3

ID	Control	Type	Tiers	Evidence	Maps to
F3	**External reporting decision.** Every Sev 1 or Sev 2 incident gets a recorded decision, made with Legal and Privacy, on customer notice, breach-notification laws, regulators, and EU AI Act incident reporting for the Dublin unit once it applies.	Corrective	All	Decision record with timestamps	NIST MANAGE 4.3 · EU Art. 73
F4	**Post-incident review.** Root cause, control changes, re-tiering and lessons shared, each tracked to closure.	Corrective	All	Review document; closed action items	NIST MANAGE 4 · SR 26-2
F5	**Decommissioning.** Retiring an agent revokes its credentials, removes tool access, and archives logs and documentation, verified by a second person.	Corrective	All	Decommission checklist; IAM confirmation of revocation	NIST GOVERN 1.7 · ISO A.6

Proportionality by tier

The tier decides how hard each control bites. A Tier 3 internal helper should not carry the burden of a Tier 1 customer-facing agent.

Requirement	Tier 1	Tier 2	Tier 3
Approves go-live	AI Governance Committee	Head of Model Risk	Business owner's executive
Highest autonomy at launch	L1	L2	L3, internal agents only
Human approval (C1)	Every irreversible action	Sampled review instead (C3)	Not required
Validation (D1)	Full independent review, including adversarial testing	Targeted independent review	Owner self-assessment, spot-checked by Model Risk

Requirement	Tier 1	Tier 2	Tier 3
Owner attestation and access recertification (A2, B5)	Quarterly	Semiannually	Semiannually
Outcome monitoring (E3)	Monthly	Quarterly	Quarterly
Revalidation (E4)	Annually	Every two years	Self-assessment
Kill-switch test (F1)	Quarterly	Annually	Annually
Moving up an autonomy level	Committee approval after 90 days of clean monitoring	Head of Model Risk	Owner

Moving up an autonomy level is a material change under D3: it needs fresh evidence, not just a date on the calendar.

Roles

The business owns each agent's risk, Model Risk challenges it, and Internal Audit checks that the controls actually work.

Role	Line	Owns
Agent owner (business)	1st	Accountable for outcomes; requests registration; approves tools and permissions; attests (A2); first call in an incident
Technical custodian (engineering)	1st	Builds and runs the agent; implements identity, logging and the kill switch (B1–B4, E1, F1); files changes (D3)
IAM and Security	1st	Issues identities only to registered agents (A1, B1); runs recertification (B5) and behavior alerts (E2); can pull the kill switch
Model Risk Management	2nd	Confirms the tier (A3); validates independently (D1, D2); approves Tier 2 go-live; can pull the kill switch

Role	Line	Owns
Compliance, Legal and Privacy	2nd	Customer disclosure (C5); regulatory mapping; external reporting decisions (F3)
AI Governance Committee	Oversight	Approves Tier 1 go-live and autonomy upgrades; accepts Tier 1 risk
Internal Audit	3rd	Tests that controls operate as designed; reports to the Audit Committee

Applied: the collections agent

The collections agent comes out as Tier 1 and launches at L1, with a human approving every email. Harbor Federal's collections team wants it to review accounts 30 or more days past due, draft a personalized reminder, and email the customer.

Tiering: action reach 3 (emails customers), autonomy 2 (L1 at launch), data 3 (customer financial data), scale 3 (customers), regulatory 3 (consumer protection rules on collection communications, privacy). Total 14, so Tier 1. The override puts it there anyway, because it sends external messages to customers.

Design decisions the framework forces:

- **Launch at L1.** The agent drafts; a collections officer approves every send (C1). Routine first reminders can move to L2 only after 90 days of clean monitoring and committee approval.
- **Bounded identity.** It runs under its own IAM identity (B1), reads one account per task, and writes only to a draft queue. The send tool requires an approval token from a named officer (B2, B4, C1).
- **Caps.** A daily send limit is set at validation; any spike pauses the agent (C2).
- **Hand-offs.** It hands off to a human if a customer disputes the debt, mentions hardship, bankruptcy or an attorney, or asks to stop contact (C4).
- **Disclosure.** Messages say they were AI-drafted where law or policy requires (C5).
- **Testing.** Validation includes cross-customer access attempts and prompt injection through customer email replies (D2).

The incident it would have stopped. In the scenario where the agent emailed a customer someone else's balance, the root cause was data retrieval not scoped to one customer. Four controls catch it, each on its own:

Control	How it stops the incident
B2 Least agency	The agent can read only the account it is working on, so the wrong balance is never in reach
D2 Adversarial testing	Cross-customer access is a required test case before go-live
C1 Approval	An officer sees the draft, and the account it is addressed to, before anything is sent
E2 Behavior monitoring	Reading a second customer's record within one task raises an alert

That is defense in depth: no single control has to be perfect.

Built against real incidents

Two public incidents shaped these controls. Neither involved a bank, and this framework would have caught both.

Incident	What happened	What failed	Controls that stop it
Replit agent deletes a production database (July 2025)	During a 12-day trial, a coding agent ran destructive commands against a live database during an explicit code freeze, wiping records for about 1,200 executives and 1,190 companies. It then told the user a rollback wasn't possible, which turned out to be wrong.	One database served preview, testing and production. Instructions were the only guardrail. The agent's own account of what it did was trusted.	B2: no production write access from a development task. C1: deletion needs human approval. F1: kill switch. E1: log what ran, not what the agent reports.

Incident	What happened	What failed	Controls that stop it
Moffatt v. Air Canada (February 2024)	The airline's chatbot told a grieving customer he could claim a bereavement fare after travel. The airline argued the chatbot was responsible for its own words. The British Columbia tribunal rejected that and ordered CA$812.02 in damages and fees.	Nobody tested the bot's answers against actual policy, and the company tried to disown its own system.	Principle 3: humans own outcomes. A2: named owner. D1: policy compliance testing. C4: hand off when the stakes are high.

The lesson from both: an instruction is not a control, and an agent's account of itself is not evidence.

Sources: eWeek on the Replit incident, heise on the shared database, MobileSyrup on the tribunal ruling.

Testing the controls

A control only counts if a test shows it operates. Three examples of how the 1st line self-tests and Internal Audit retests:

Control	Test procedure	Sample	Pass criteria
A1 Register before credentials	Pull IAM's full list of agent identities and reconcile it against the AI inventory	Full population, automated monthly	100% match. Any identity with no inventory ID is an exception, logged as an issue

Control	Test procedure	Sample	Pass criteria
B4 Recorded delegation	Pick actions from the quarter's logs; trace each to its delegator and confirm the delegator held that permission at the time	25 actions per Tier 1 agent per quarter	25 of 25 show a valid delegator. One miss means the control failed
F1 Kill switch	Pause the agent without a code release during a low-traffic window; time it; confirm no tool call succeeds afterwards	Every Tier 1 agent, quarterly	Paused within the 5-minute target, with zero successful tool calls after the pause

Results go in the control register. Each failure becomes an issue with an owner and a due date.

Where the frameworks are silent

None of the four main references tells a bank how to identify an agent or record whose authority it acts on, which is why controls B1, B4 and E1 exist.

Framework	What it covers	What it leaves open for agents	Filled by
NIST AI RMF 1.0	Inventory, roles, monitoring and disengagement, stated as outcomes	How to identify an agent or record who it acts for. NIST is also revising version 1.0	B1, B4
ISO/IEC 42001	A management system plus 38 Annex A controls, including life-cycle controls and event logging	No control for non-human identity or delegation. It certifies the management system, not individual agents	B1, B4

Framework	What it covers	What it leaves open for agents	Filled by
EU AI Act	Logging, human oversight and incident reporting for high-risk systems; transparency for systems that interact with people	Logs must make operation traceable, but recording the delegating person isn't specified. Many banking agents won't be high-risk, so much of this serves as a design reference	B4, E1
SR 26-2	Inventory, risk-based validation, ongoing monitoring, third-party models	Generative and agentic AI are explicitly outside its scope; banks are expected to govern them with separate frameworks	The whole framework, revisited when that guidance is issued

OWASP's LLM and agentic lists name the risks (excessive agency, prompt injection) but are security guidance, not a governance model. These identity and delegation controls are the ones an examiner is least likely to find elsewhere, and where future guidance is most likely to land.

What my standards work adds

Six design choices here go further than the frameworks require, and each one comes from work I've done.

My work	The point	Where it lands
W3C AI KR Community Group, §4.1 comparison semantics (co-author, Sept 2026)	A complete, faithful audit trail can still miss what happened: most agent systems log the action the agent declared, not the request that actually ran	E1 logs the request as the receiving system executed it. A mismatch with the declared action raises an alert

My work	The point	Where it lands
Same work: audit-evidence failure classes	Comparing records can fail silently. Unicode that isn't normalized makes one identifier look like two; large numbers in JSON lose precision, so two different values look identical	Logs that are hashed or matched across systems are canonicalized first (RFC 8785) and tested against known failure vectors
IETF conformance test set (draft-etcheverry-action-ref)	Labeling each failure fail-open or fail-closed makes the risk explicit instead of leaving it to prose	D2 labels every adversarial test; a fail-open result blocks go-live
Agentic Identity Guard research (Community Dreams Foundation)	Authority checked once at login can outlive the authority itself, so it has to be verified at the moment of action	Identity and permission checks run on every tool call, as the control path shows
TRAIL BindingProofCredential (§5.4.5, merged in v1.3.0)	An organization and its agent can each attest to their relationship, verifiable by any third party	Tier 1 option for A2: the owner–agent link is a signed credential, not just a field in a spreadsheet
Provable Agent Authority proof of concept (Aug 2026)	Each agent action can be tied to a verified mandate in a tamper-evident log	Reference implementation for B4 and E1, tested against tampered records, wrong-key signatures and forged approvals

Design notes: why these numbers

None of these numbers comes from a standard. They are judgment calls, and this is the reasoning I would defend.

- **No L3 for customer-facing or financial actions.** L3 removes the last point where a person catches an error before it reaches a customer, and Air Canada shows the company owns whatever its agent says. I would revisit this only with months of L2

sampling evidence, not on request.

- **Override to Tier 1 for external, financial or irreversible actions.** Scoring alone lets a dangerous agent average its way down a tier. What an agent can do to the outside world matters more than any other factor, so that factor decides alone.
- **Kill switch within 5 minutes.** Fast enough to cap damage inside the C2 send limits, and achievable by a non-engineer without a release. The quarterly test is what makes the number real; an untested kill switch is a hope.
- **90 days before an autonomy upgrade.** That covers three monthly collections cycles and enough sampled reviews to see a stable error rate. Evidence decides; 90 days is the minimum, not the trigger.
- **10% weekly sample at Tier 1 and L2.** A starting point I would tune to volume: high enough to surface a few-percent error rate within weeks, low enough that reviewers keep doing it.
- **Recorded delegation at Tiers 1 and 2, not Tier 3.** Tier 3 agents are internal, low-reach, and often run on a schedule with no human request behind them. Recording delegation there costs more than it proves.
- **Least agency instead of least privilege.** In the Replit incident the problem wasn't one permission. The agent had access it shouldn't have used and the autonomy to use it unprompted. Limiting tools, permissions and autonomy separately covers all three.

References

- NIST AI Risk Management Framework and the AI RMF Core (subcategories GOVERN 1.6, 1.7; MANAGE 2.4, 4.1, 4.3)
- ISO/IEC 42001 Annex A control areas (secondary summary; confirm wording against the licensed standard)
- SR 26-2, revised interagency model risk management guidance and Davis Polk summary
- EU AI Act high-risk timeline after the Digital Omnibus
- OWASP: Excessive Agency and the 2026 edition and agentic list
- RFC 8693, OAuth 2.0 Token Exchange